LABORATUVAR 5 · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 20.10.2026

Kavram: SBOM yazılım malzeme listesidir · **CVE** açığın kayıt numarasıdır · **CVSS** ciddiyeti 0–10 arası ölçer. Bir CVE'nin sizi etkilemesi için üç şart birden gerekir: **bileşen var**, **sürüm etkileniyor**, **açık ulaşılabilir**. CVSS önemi gösterir, riski değil; risk, ulaşılabilirliğe ve emniyet fonksiyonunun bağımsızlığına bağlıdır.

Verilen zafiyet kaydı

BİLEŞEN	SÜRÜM	CVE	ÖNEM	YAMA
Arma Kart Component X kontrol kartı firmware kütüphanesi	2.4	CVE-XXXX-XXXX	Critical (CVSS 9.8)	Mevcut

VEKTÖR V `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` — ağdan, kimlik doğrulaması ve kullanıcı etkileşimi gerektirmeden uzaktan kod çalıştırma (9.8'in tipik vektörü)

SBOM'dan kesit V

No.	Varlık (LAB 2)	Yazılım bileşenleri	Component X?
3	**Arma Kart [EE51KAR]** G	Kart firmware'i · RTOS çekirdeği · TCP/IP yığını · **Component X 2.4 (HTTP/ağ kütüphanesi)** · RS-485/Wiegand sürücüleri	**VAR · 2.4**
4	Safety PLC (hedef)	PLC üreticisinin firmware'i · emniyet programı (imzalı, CRC'li)	yok
13	Kulübe PC	Windows 10 IoT · Arma WOC G · .NET çalışma zamanı · TeamViewer (kaldırılacak)	yok
14	4G router	Router işletim sistemi · VPN istemcisi	yok
10 · 12	Plaka kamerası · YZ kutusu	Kamera firmware'i · Linux + çıkarım motoru + model dosyası	yok
D1	Arma Mobil G	Android/iOS uygulaması + üçüncü taraf kütüphaneler	yok

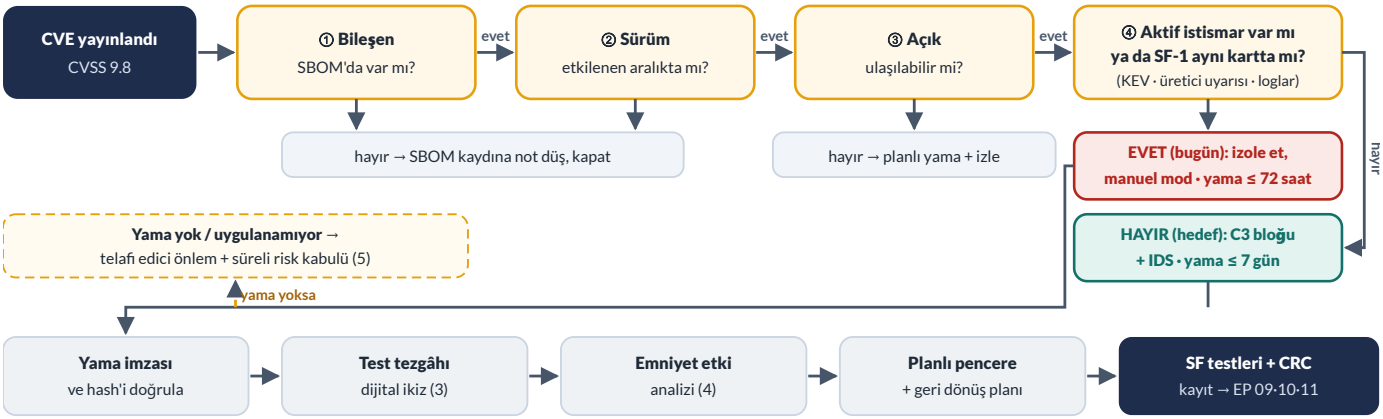
SBOM'u üretici sağlar (CycloneDX ya da SPDX biçiminde). AB Siber Dayanıklılık Yasası (CRA), üreticiden en azından üst düzey bağımlılıkları kapsayan, makinece okunabilir bir SBOM ister (Ek I, Bölüm II; 11.12.2027'den itibaren). Bu kesit örnektir.

Görev — karar akışı

1 **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

Şart	Nasıl kontrol edilir?	Bugün V	Hedef mimaride (LAB 4)
1 · Bileşen var mı?	Tüm SBOM'larda Component X aranır	**EVET — Arma Kart'ta**	**EVET — aynı kart**
2 · Sürüm etkileniyor mu?	Etkilenen aralık (ör. < 2.6) ile 2.4 karşılaştırılır	**EVET**	**EVET**
3 · Ulaşılabilir mi?	AV:N, yani ağdan: hangi bölgeden?	**EVET — internet (4G), Wi-Fi, kulübe ağı**	**KISMEN — yalnız kulübe PC'sinden, C3 izin listesiyle**
Sonuç		**3/3 · etkiliyor, ACİL**	**2/3 + dar yol · etkiliyor, planlı**

Karar akışı (bu CVE için)



Parantezdeki numaralar föyün sorularıdır. Akış bu CVE için iki kez yürütüldü: bugünkü mimaride ④ "evet" çıkıyor (SF-1 uzaktan ulaşılabilen kartta), hedef mimaride "hayır".

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Bu makinede "üretimi durdurmak", kapıyı ve dolayısıyla tanker akışını durdurmak demek. Tam durdurmanın da iki yüzü var: bariyerler aşağıda kalırsa kapı korumasız kalır; yukarıda kalırsa tanker kuyruğu kamu yoluna taşar ve tesisin hammaddesi kesilir.

Bugün V **EVET — otomatik modu durdururuz**

4G fiziksel olarak sökülür, Arma Mobil kapatılır. Bariyerler yukarıda sabitlenir; her araç görevli tarafından yerel butonla ve gözle kontrol edilerek alınır. Neden: internetten ulaşılabilen 9.8'lik bir açık ile aynı karttaki SF-1, hem kapıyı açtırabilir hem insana zarar verebilir.

Hedef mimaride **HAYIR**

SF-1 bağımsız, insan korunur. Açığa yalnız kulübe PC'sinden C3 üzerinden ulaşılır; zafiyetli servis C3'te hemen engellenir. Yama 7 gün içinde, test edilerek uygulanır. Aktif istismar kanıtı (KEV, üretici uyarısı, anormal komut kaydı) gelirse bugünkü moda geçilir.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Bu kart bariyeri hareket ettiriyor; test edilmemiş bir yama, açığın kendisinden daha büyük bir risk olabilir.

1. **Doğrula:** yama yalnız üretici portalından alınır; imzası ve hash'i üreticinin yayımladığıyla karşılaştırılır (sahte yamaya karşı).
2. **Test tezgâhı:** entegratörde aynı Arma Kart ve firmware'le kurulu bir "dijital ikiz"; loop, fotosel ve hidrolik valfler simüle edilir. Aç/kapat/durum komutları, WOC haberleşmesi, plaka/kart entegrasyonu ve enerji kes-ver davranışı (GR-5) denenir.
3. **Sahada:** en düşük trafikli pencerede (ör. Pazar 02:00–04:00). Görevli prosedürü ve iç bariyer hattı yedekte bekler; önceki imzalı firmware geri dönüş için hazırdır. LAB 2'deki C8 kuralı geçerli: taramadan geçmiş servis dizüstü, iki kişi.
4. **Sonra:** LAB 1 haritasındaki SF testleri, parametre CRC karşılaştırması ve 24 saat yoğun izleme.

4 **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

Bugün V **EVET**

SF-1'in mantığı yamalanan firmware'in içinde. Kartın firmware'i değişince emniyet fonksiyonunun doğrulaması geçersiz olur: yazılım değişikliği etki analizi + SF-1/2/3 testlerinin tamamı yeniden yapılır.

Hedef mimaride **BÜYÜK OLASILIKLA HAYIR**

Yama Z1'deki Arma Kart'a; SF-1 Z0'daki Safety PLC'de. Yine de "büyük olasılıkla" kanıtlanmadan kabul edilmez.

Nasıl anlarız? (1) **Etki analizi:** yama notlarındaki değişen modüller, LAB 1 Safety Function Map'teki SF giriş/çıkış ve zamanlamalarıyla eşleştirilir. (2) **İmza:** Safety PLC programının imzası/CRC'si yama öncesi ve sonrası aynı olmalı. (3) **Arayüz:** C1 üzerinden giden "yükseltme talebi" sinyalinin davranışı değişmemeli. (4) **Kısaltılmış doğrulama:** yine de GR-2 (alan doluyken komut → hareket yok) ve GR-5 testleri yapılır. **Kural:** şüphede tam doğrulama.

5 **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

Amaç, üç şarttan birini, en kolayı "ulaşılabilirlik"i ortadan kaldırmak ve kalan riski süreli olarak kayda almak.

#	Önlem	Ne yapar?
1	**Ulaşılabilirliği kes**	Zafiyetli servis (HTTP/80) C3'te engellenir; 4G sökülür; Arma Mobil'in uzaktan komutu kapatılır → 3. şart ortadan kalkar
2	**Sanal yama**	C3'teki endüstriyel güvenlik duvarında / IPS'te bu CVE'ye özel imza; istismar trafiği karta ulaşmadan düşer
3	**İzleme**	Z1 segmentinde OT saldırı tespit sistemi (IDS); yeni bir bağlantı ya da beklenmeyen komut güvenlik merkezine alarm üretir
4	**Fiziksel**	Pano kilitli, servis portu mühürlü; mühür her vardiyada kontrol edilir
5	**Emniyet** (bugünkü mimaride kritik)	Geçici, bağımsız bir emniyet rölesi: loop + fotosel doğrudan pompa kontaktörünü keser. SF-1 karttan bağımsızlaşır; kart ele geçirilse bile insan korunur
6	**Süreli risk kabulü**	Sorumlu + bitiş tarihi (en çok 30 gün) + üreticiden yama takvimi talebi. Aktif istismar varsa üretici bunu CRA gereği 24 saat içinde bildirmekle yükümlü (11.09.2026'dan beri)

Çıktı — Vulnerability Decision

CVE / bileşen	CVE-XXXX-XXXX · Component X 2.4 · CVSS 9.8 (AV:N/AC:L/PR:N/UI:N)
Etkilenen varlık	3 · Arma Kart [EE51KAR], Z1. Safety PLC'de ve diğer varlıklarda yok
Etkiliyor mu?	Bugün 3/3 → **evet, acil** · Hedef mimaride 2/3 + dar yol → **evet, planlı**
İlk 24 saat	Bugün: 4G sökülür, Mobil kapatılır, manuel mod. Hedef: C3'te HTTP/80 engeli + IDS kuralı
Yama	İmza doğrulama → test tezgâhı → planlı pencere. Süre: bugün ≤ 72 saat, hedef ≤ 7 gün
Emniyet doğrulaması	Bugün: tam yeniden doğrulama · Hedef: etki analizi + imza karşılaştırması + GR-2/GR-5 testleri
Yama yoksa	Telafi edici önlemler 1–6 + en çok 30 günlük süreli risk kabulü
Sorumlular	OT güvenlik sorumlusu (karar) · entegratör (test ve uygulama) · İSG uzmanı (emniyet doğrulaması) · güvenlik müdürü (manuel mod)
Kanıt	SBOM sürümü, bu karar kaydı, test raporu, imza/CRC karşılaştırması, değişiklik kaydı

G üreticinin sitesinde yazan bilgi · V eğitim senaryosu varsayımı, **Arma ürünü hakkında iddia değildir**; CVE, bileşen ve SBOM içeriği föyün verdiği örnek kayda göre kurgulanmıştır. Dayanaklar: CVSS v3.1 · CISA KEV (bilinen istismar edilen açıklar) · ISO 13849-1:2023 (yazılım değişikliğinde doğrulama) · CRA (AB 2024/2847) Madde 14 ve Ek I Bölüm II.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.